HTTP Observatory Report

Report Feedback

Scan summary: forensiq.pt

A+

Score: 120 / 100
Scan Time: 3 minutes ago
Tests Passed: 10 / 10

Scan results

Scoring

Test	Score	Reason	Recommendation
Content Security Policy (CSP)	0 ✓	Content Security Policy (CSP) implemented with unsafe sources inside style-src. This includes `'unsafe-inline'`, `data:` or overly broad sources such as `https`. `'form-action'` is set to `'self'`, `'none'` or `'specific source'`	Lock down `style-src` directive, removing `'unsafe-inline'`, `data:` and broad source
Cookies	-	No cookies detected	None
Cross Origin Resource Sharing (CORS)	0 ✓	Content is not visible via cross-origin resource sharing (CORS) files or	None

Test	Score	Reason	Recommendation
		headers.	
Redirection	0 ✓	Initial redirection is to HTTPS on same host, final destination is HTTPS	None
Referrer Policy	+5 ✓	**`Referrer-Policy`** header set to **`no-referrer`**, **`same-origin`**, **`strict-origin`** or **`strict-origin-when-cross-origin`**.	None
Strict Transport Security (HSTS)	0 ✓	**`Strict-Transport-Security`** header set to a minimum of six months (15768000).	Consider preloading: this requires adding the **`preload`** and **`includeSubDomains`** directives and setting **`max-age`** to at least **`31536000`** (1 year), and submitting your site to https://hstspreload.org/.
Subresource Integrity	-	Subresource Integrity (SRI) not implemented, but all scripts are loaded from a similar origin.	Add SRI for bonus points.
X-Content-Type-Options	0 ✓	**`X-Content-Type-Options`** header set to **`nosniff`**.	None
X-Frame-Options	+5 ✓	**`X-Frame-Options`** (XFO) implemented via the CSP frame-ancestors directive.	None
Cross Origin Resource Policy	+10 ✓	Cross Origin Resource Policy (CORP) implemented, prevents leaks into cross-origin contexts.	None

CSP analysis

✓ Content Security Policy (CSP) implemented with unsafe sources inside style-src. This includes `'unsafe-inline'`, `data:` or overly broad sources such as `https`. `'form-action'` is set to `'self'`, `'none'` or `'specific source'`

Test	Result	Info
Blocks execution of inline JavaScript by not allowing `'unsafe-inline'` inside `script-src`	✓	Blocking the execution of inline JavaScript provides CSP's strongest protection against cross-site scripting attacks. Moving JavaScript to external files can also help make your site more maintainable.
Blocks execution of JavaScript's `eval()` function by not allowing `'unsafe-eval'` inside `script-src`	✓	Blocking the use of JavaScript's `eval()` function can help prevent the execution of untrusted code.
Blocks execution of plug-ins, using `object-src` restrictions	✓	Blocking the execution of plug-ins via `object-src 'none'` o as inherited from `default-src` can prevent attackers from loading Flash or Java in the context of your page.
Blocks inline styles by not allowing `'unsafe-inline'` inside `style-src`	✗	Blocking inline styles can help prevent attackers from modifying the contents or appearance of your page. Moving styles to external stylesheets can also help make your site more maintainable.
Blocks loading of active content over HTTP or FTP	✓	Loading JavaScript or plugins can allow a man-in-the-middl to execute arbitrary code or your website. Restricting your policy and changing links to HTTPS can help prevent this.
Blocks loading of passive content over HTTP or FTP	✓	This site's Content Security Policy allows the loading of passive content such as images or videos over insecure protocols such as HTTP or FTP. Consider changing them to load them over HTTPS.
Clickjacking protection, using `frame-ancestors`	✓	The use of CSP's `frame-ancestors` directive offers fine-grained control over who can frame your site.

Test	Result	Info
Deny by default, using **`default-src 'none'`**	✗	Denying by default using **`default-src 'none'`** can ensure th your Content Security Policy doesn't allow the loading of resources you didn't intend to allow.
Restricts use of the **`<base>`** tag by using **`base-uri 'none'`**, **`base-uri 'self'`**, or specific origins.	✓	The **`<base>`** tag can be used to trick your site into loading scripts from untrusted origins.
Restricts where **`<form>`** contents may be submitted by using **`form-action 'none'`**, **`form-action 'self'`**, or specific URIs	✓	Malicious JavaScript or content injection could modify wher sensitive form data is submitted to or create additional form for data exfiltration.
Uses CSP3's **`'strict-dynamic'`** directive to allow dynamic script loading (optional)	-	**`'strict-dynamic'`** lets you use a JavaScript shim loader to load all your site's JavaScript dynamically, without having to track **`script-src`** origins.

Cookies

No cookies detected

Raw server headers

Header	Value
Via	1.1 fly.io, 1.1 fly.io
Date	Sat, 18 Apr 2026 02:07:01 GMT
Vary	origin, Accept-Encoding
Server	Fly/9e64c111f (2026-04-16)

Header	Value
Connection	close
Content-Type	text/html; charset=utf-8
Content-Length	2177
Fly-Request-Id	01KPF5ENFY8GEZA7B04GBHTECH-sjc
Referrer-Policy	strict-origin-when-cross-origin
X-Frame-Options	DENY
X-Correlation-Id	a2b61b5e-4fae-421e-b38c-38c7d0a258cb
Permissions-Policy	accelerometer=(), camera=(), geolocation=(self), gyroscope=(), magnetometer=(), microphone=(), payment=(), usb=()
X-Content-Type-Options	nosniff
Content-Security-Policy	default-src 'self'; script-src 'self' https://cdnjs.cloudflare.com; style-src 'self' 'unsafe-inline' https://cdnjs.cloudflare.com https://fonts.googleapis.com; connect-src 'self' https://nominatim.openstreetmap.org; img-src 'self' data: https://*.tile.openstreetmap.org https://cdnjs.cloudflare.com; font-src 'self' https://cdnjs.cloudflare.com https://fonts.gstatic.com; object-src 'none'; frame-src 'none'; base-uri 'self'; frame-ancestors 'none'; form-action 'self'; upgrade-insecure-requests
Strict-Transport-Security	max-age=31536000; includeSubDomains; preload
Cross-Origin-Opener-Policy	same-origin
Cross-Origin-Resource-Policy	same-origin

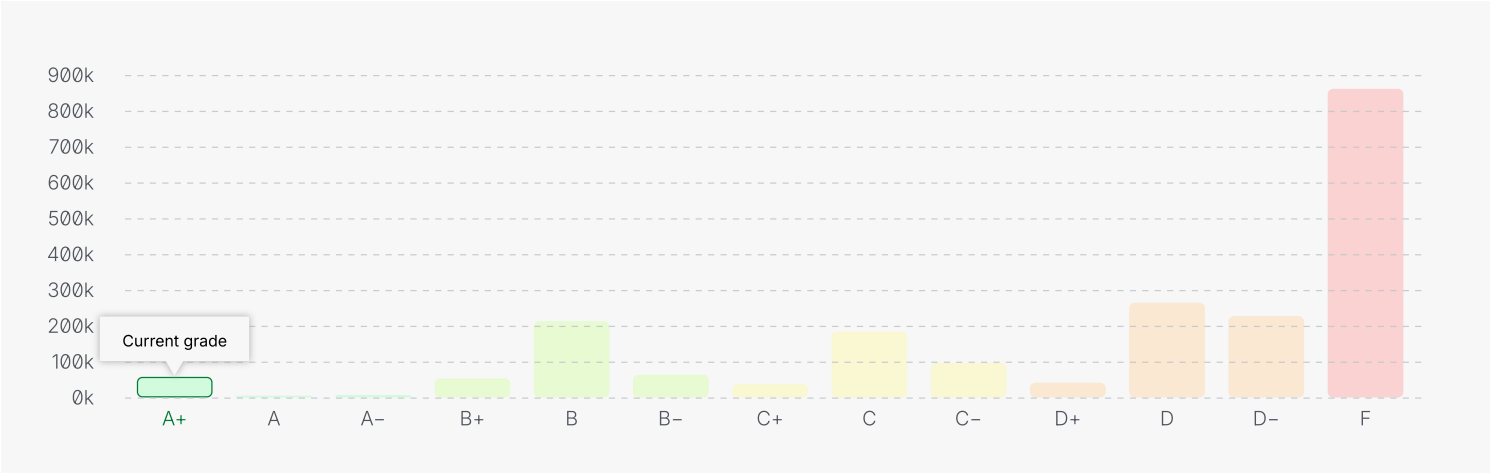
Scan history

Changes in score over time

Date	Score	Grade
18/04/2026, 03:06:56	120	A+

Benchmark comparison

Performance trends from the past year



Refer to this graph to assess the website's current status. By following the recommendations provided and rescanning, you can expect an improvement in the website's grade.

Your blueprint for a better internet.